

Sprint chapter	Sheet	Task where this sheet is filled out
I. Developing threat models	Key Assets	4.1.2 Identifying key assets (Key Assets)
	Threat Actors	4.1.4 Profiling threat actors (Threat Actors)
II. Conduct gap analysis	Attack Surface	4.2.1 Mapping an attack surface (Attack Surface)
	Risks	4.2.2 Evaluating risks (Risks)
	Attack Vectors	4.2.4 Identifying attack vectors (Attack Vectors)
	Attack Scenarios	4.2.5 Envisioning attack scenarios (Attack Scenarios)
III. Choosing solutions	Solutions	4.3.2 Assessing detection solutions: continuous monitoring (Data sources)
		4.3.5 Assessing preventive solutions (Mitigations)
		4.3.8 Assessing detection solutions: honeypots (Honeypots)
IV. Creating a formal roadmap	Goals	4.4.2 Setting milestones for each solution (Goals)
	Stakeholders	4.4.3 Crafting arguments for each stakeholder (Stakeholders)

Use the info provided about the org to identify key assets included in scope of threat model	Add notes about this asset.
4.1.2	4.1.2
Key Assets	Notes
Intellectual property (IP): proprietary game source code.	Production gaming servers exist in their own network segment. API server (api.xibalbagames.com) is built on top of Express.js. Gaming servers (xibalbagames.com) exist in the same network segment as the API server supplying data to stats. xibalbainteractive.com . Administrative interfaces for the game servers are accessible over the internet without IP whitelisting or multi-factor authentication.
Payment information of users for billing (paid subscriptions).	Credit/debit card information of users. Payment information of users is stored on a dedicated Payment Processing Server. Server (pay.xibalbagames.com) is in separate network segment from development and gaming servers. PCI-DSS compliant.
In-game private chat system	features end to end encryption, protecting the privacy of the conversation of users

Complete the Key Assets sheet first to pre-populate this column's dropdown!		Why might this TA be motivated to access this asset?	How might we expect this TA to attack this asset?
4.1.2 Key Assets	4.1.4 Threat Actors	4.1.4 Motivations ("why")	4.1.4
Payment information of users for billing (paid subscriptions).	Cybercriminals	Financial gain through theft of fraud	• Data exfiltration for reselling • Malware infections • Card-skimming
Intellectual property (IP): proprietary game source code.	Cybercriminals	Selling stolen data on the dark web	• Phishing emails • Drive-by downloads • Ransomware to lock and extor
In-game private chat system	Script Kiddies	Gaining notoriety in online forums or community	• Running DDoS scripts • Brute-forcing simple passwords • Deploying off-the-shelf malware

Complete the column's dropdown!	Key Assets sheet first to pre-populate this	Name system component here.	Classify this component of the system.	How does this attack surface involve the	Key Asset?	Does this surface connect to any other surfaces?
4.1.2	4.2.1	4.2.1	4.2.1	4.2.1	4.2.1	4.2.1
Key Assets	Attack Surface	Component type	Relationship			Related surfaces
Intellectual property (IP): proprietary game source code.	Developer Environments	Software	in this attack surface adversaries can get in by the defaults from the creator such as weak endpoint security and once they get in they will have the access to the games of an admin.			Financial
Payment information of users for billing (paid subscriptions).	Billing Staff & Social Engineering	Data	This surface contains all the financial information of users such as billing informations.			User credentials and access logs
In-game private chat system	In game user account access	Data	this surface can provide access to the in-game chat one has with other users.			User credentials and access logs

Complete the Attack Surface sheet first to pre-populate this column's dropdown!	List anything that could go wrong with this	Attack Surface	What is the likelihood of this Risk being exploited?	What is the impact if this Risk were successfully exploited?	Add likelihood and impact ratings together.
4.2.1	4.2.2	4.2.2	4.2.2	4.2.2	4.2.2
Attack Surface	Risks	Likelihood	Impact	Rating	
Developer Environments	Poor role-based access (e.g., interns with full repo access)	3 (Possible)	5 (Catastrophic)	7	
Billing Staff & Social Engineering	Phishing email pretending to be a customer or employee	4 (Likely)	4 (Major)	7	
In game user account access	rogue employees	3 (Possible)	3 (Moderate)	8	

Complete the	Risks sheet first to pre-populate this column's dropdown!	List any TTPs that might be involved in this Risk.	Add the URL to this particular ATT&CK TTP.	Note how this TTP relates to this Risk.	Imagine a scenario where a Threat Actor might use this TTP.
4.2.2		4.2.4	4.2.4	4.2.4	4.2.4
Risks		Attack Vectors	ATT&CK TTP URL	Relevance	Scenarios
Phishing email pretending to be a customer or employee		T1598.003: Phishing for Information	https://attack.mitre.org/techniques/T1598/003/	TA may use phishing emails to lure an insider acting as an employee or may pretend to "sell in game purchases" to gain customer's billing information which they will steal later.	TA can send phishing email containing outsource links with malware or other risky virus that will put sensitive information at risk.
Phishing email pretending to be a customer or employee		T1204: User Execution	https://attack.mitre.org/techniques/T1204/		
Phishing email pretending to be a customer or employee		T1554: Compromise Host Software Binary	https://attack.mitre.org/techniques/T1554/		
Phishing email pretending to be a customer or employee		T1055: Process Injection	https://attack.mitre.org/techniques/T1055/		
Phishing email pretending to be a customer or employee		T1567: Exfiltration Over Web Service	https://attack.mitre.org/techniques/T1567/		
rogue employees		T1586: Compromise Accounts	https://attack.mitre.org/techniques/T1586/	TA may be an insider who can use the company inside information or knowledge to harm the company.	TA can act as a spy and transfer valuable and sensitive information and act as an adversary when needed.
rogue employees		T1651: Cloud Administration Command	https://attack.mitre.org/techniques/T1651/		
rogue employees		T1534: Internal Spearphishing	https://attack.mitre.org/techniques/T1534/		
rogue employees		T1665: Hide Infrastructure	https://attack.mitre.org/techniques/T1665/		
rogue employees		T1011: Exfiltration Over Web Service	https://attack.mitre.org/techniques/T1011/		
rogue employees		T1495: Firmware Corruption	https://attack.mitre.org/techniques/T1495/		
"Poor role-based access (e.g., interns with full repo access)"		T1098: Account Manipulation	https://attack.mitre.org/techniques/T1098/	TA may manipulate accounts that have poor role based access.	TA can manipulate accounts that are used or modified by interns or groups of employees with limited knowledge on cybersecurity thus giving access to TA unknowingly.
"Poor role-based access (e.g., interns with full repo access)"		T1567: Exfiltration Over Web Service	https://attack.mitre.org/techniques/T1567/	TA can exploit accounts that are handled by interns with full repo access	TA can manipulate accounts that are already existing and exfiltrate data from those already existing accounts*
"Poor role-based access (e.g., interns with full repo access)"		T1565: Data Manipulation	https://attack.mitre.org/techniques/T1565/		
"Poor role-based access (e.g., interns with full repo access)"		T1496: Resource Hijacking	https://attack.mitre.org/techniques/T1496/		

Title of your attack scenario.	Complete the Attack Vectors sheet first to pre-populate this column's dropdown!	Describe in detail a scenario chaining these TTPs together to result in TA accessing Key Asset .
4.2.5 Attack Scenario	4.2.4 Attack Vectors	4.2.5 Details
From manipulating account to hijacking internal resources	T1098: Account Manipulation, T1567: Exfiltration Over Web Service	Manipulating an Admins account and exploiting it to the furthest extent. Using the Admins account to share all the information by data manipulation and sharing it in the black market
Malware infested link through phishing email causing financial damage	T1598.003: Phishing for Information, T1204: User Execution, T1554: Compromise Host Software Binary, T1055: Process Injection, T1567: Exfiltration Over Web Service	Sending a phishing email with malware disguised as an insider such as employee or customer. Waiting for the user to click on the link, then process injection begins after all the information is now on the hands of the TA which they later transfer to their platform
Rogue employees using their own accounts to implant spyware and exfiltrate without anybodys knowledge	T1586: Compromise Accounts, T1651: Cloud Administration Command, T1534: Internal Spearphishing, T1665: Hide Infrastructure, T1011: Exfiltration Over Web Service, T1495: Firmware Corruption	Using their own account to implement internal spearfishing and and putting spyware which they later hide and transfer information as the spyware gets them. Thus, causing corruption

Complete the Attack Vectors sheet first to pre-populate this column's dropdown!	List detective or preventive solutions associated with TTP.					
T1567: Exfiltration Over Web Service	DS0015: Application Log (Application Log Content)	DETECTIVE: Data source	YES	https://attack.r	Review logs for SaaS services, including Office 365 and Google Workspace, to detect the configuration of new webhooks or other features that could be abused to exfiltrate data. Analytic 1 - Detecting Large File Uploads to Web Services	(create)
T1586: Compromise Accounts	DS0021: Persona (Social Media)	DETECTIVE: Data source	YES	https://attack.r	Consider monitoring social media activity related to your organization. Suspicious activity may include personas claiming to work for your organization or recently modified accounts making numerous connection requests to accounts affiliated with your organization. Much of this activity will take place outside the visibility of the target organization, making detection of this behavior difficult. Detection efforts may be focused on related stages of the adversary lifecycle, such as during Initial Access (ex: Phishing).	(create), (ingest into SIEM)
T1598.003: Phishing for Information	DS0029: Network Traffic (Network Traffic Content)	DETECTIVE: Data source	YES	https://attack.r	Monitor and analyze traffic patterns and packet inspection associated to protocol(s) that do not follow the expected protocol standards and traffic flows (e.g extraneous packets that do not belong to established flows, gratuitous or anomalous traffic patterns, anomalous syntax, or structure). Consider correlation with process monitoring and command line to detect anomalous processes execution and command line arguments associated to traffic patterns (e.g. monitor anomalies in use of files that do not normally initiate connections for respective protocol(s)).	(exists), (already ingested to SIEM)
T1098: Account Manipulation, T1651: Cloud Administration Command	M1026: Privileged Account Management	PREVENTIVE: Mitigation	YES	https://attack.r	Privileged Account Management focuses on implementing policies, controls, and tools to securely manage privileged accounts (e.g., SYSTEM, root, or administrative accounts).	(implement)
T1567: Exfiltration Over Web Service, T1011: Exfiltration Over Web Service	M1057: Data loss prevention	PREVENTIVE: Mitigation	YES	https://attack.r	Data Loss Prevention (DLP) involves implementing strategies and technologies to identify, categorize, monitor, and control the movement of sensitive data within an organization. This includes protecting data formats indicative of Personally Identifiable Information (PII), intellectual property, or financial data from unauthorized access, transmission, or exfiltration. DLP solutions integrate with network, endpoint, and cloud platforms to enforce security policies and prevent accidental or malicious data leaks.	(implement)
T1098: Account Manipulation	T1098: Active Directory (Active Directory Object Modification)	DETECTIVE: Data source	YES	https://attack.r	Monitor events for changes to account objects and/or permissions on systems and the domain, such as event IDs 4738, 4728 and 4670. Monitor for modification of accounts in correlation with other suspicious activity. Changes may occur at unusual times or from unusual systems. Especially flag events where the subject and target accounts differ or that include additional flags such as changing a password without knowledge of the old password. Monitor for unusual permissions changes that may indicate excessively broad permissions being granted to compromised accounts.	(create)
T1598.003: Phishing for Information	Honeyemail to detect phishing email	DETECTIVE: Honeygot	YES		A legitimate but unused email address from company's domain (matched with an enticing fake persona) listed in company's public-facing infrastructure. Used to identify targeted phishing campaigns.	(create), (ingest alerts into SIEM)
T1586: Compromise Accounts	Honeyfile honeytoken honeydata to detect suspicious activity	DETECTIVE: Honeygot	YES		Enticing files or data that alert as soon as opened/accessed/viewed	(create), (ingest alerts into SIEM)
T1098: Account Manipulation	Honeycreds to spot unusual login attempt	DETECTIVE: Honeygot	YES		Enticing credentials that alert as soon as login attempt occurs	(create), (ingest alerts into SIEM)

Complete the Solutions sheet first to pre-populate this column's dropdown!								
4.3.2 · 4.3.5 · 4.3.8	4.4.1	4.4.1	4.4.1	4.4.1	4.4.1	4.4.1	4.4.1	4.4.1
Solution	Goal	Specific	Measurable	Achievable	Relevant	Time-bound	Checklist	Formal Deadline
DS0021: Persona (Social Media)	Make monitoring social media a priority every once in a week	Monitor social media accounts related to the organization	success is measured by the findings of malicious/phishing activities on social media	easily achievable by determining a certain time to social media monitoring	helps protect the organizations reputation against any scams and scandals.	Every Friday should be the weekly deadline for monitoring until 3 months from implementing this solution	☐	3 months
DS0029: Network Traffic (Network Traffic Content)	Develop course that educated on cybersecurity awareness among the employees and customers within 2 months	Develop a course for cybersecurity awareness	success is measured by the completion of the creation of the course	2 months is enough to prepare cybersecurity awareness course	helps protect sensitive info such as billing or basic contact information of employees or customers.	Deadline is set at 2 months	☐	2 months
T1098: Active Directory (Active Directory Object Modification)	Implement Two/three step verification process for administrative access within 1 month	Create 2/3 step verification process to get access to admin control	Success is measured by the completion of creation of the verification process	Easily achievable in 1 month	Helps restrict and limit admin control to anybody but the admin	Deadline is set at 1 month after receiving the message	☐	1 month
M1026: Privileged Account Management	Provide each employee with a personal laptop within 3 months, which they will use to access official work	Provide each employee an office laptop which will have SIEM and can be monitored by cyber analysts	Success is measured by confirming each employee have their own personal laptop	3 months is a reasonable timeframe to purchase and set up SIEMs in laptop	Creates less confusion and mishandling of data by other employees	Deadline is set by 3 months	☐	3 months
M1057: Data loss prevention	Upload SIEM on every company owned device within 3 months	Upload SIEM to continuously monitor data activity	Success is measured by successful implementation of SIEM on every device	3 months is more than enough time to achieve this goal	Monitors the activity of sensitive data	Deadline is set at 3 months upon receiving the task	☐	3 months
Honeymail to detect phishing email	Create a honeymail in 1 month	Create honeymail	Success is measured by successfully implementing honeymail	Easily achievable in 1 month	Helps identify and spot attackers trying a phishing attack	Deadline is set at 1 month	☐	1 month
Honeyfile honeytoken honeydata to detect suspicious activity	Create any of the honeypot from this solution within 2 months	Create honeypots to track suspicious activity among sensitive data to all company owned devices. Honeypot location or name shouldnt be known to any except the cyber professionals and admin	Success is measured by the implementation of honeypots across all devices	Easily achievable by 2 months	Helps track malicious activity or transfer of data	Deadline is set at 2 months	☐	2 months
Honeycreds to spot unusual login attempt	Create honeycreds to all company owned devices uniquely for all individual devices within 2 months	Create honeycreds to be notified when somebody is trying to access device	Success is measured by the completion of honeycreds	Achievable in 2 months	Helps notify cyber professionals when a suspicious attempt to login is occurring within any of the company devices	Deadline is set at 2 months	☐	2 months

Complete the column's dropdown! 4.3.2 - 4.3.5 - 4.3.8	Solutions sheet first to pre-populate this column's dropdown!	Which audience do you need to communicate value to? 4.4.3	What risk or issue does solution address? 4.4.3	How does solution solve the problem? 4.4.3	Why is solution effective? 4.4.3	What specific examples or statistics can strengthen your argument? 4.4.3	Why should this stakeholder care? 4.4.3
Solution		Stakeholder	State the problem	Propose the solution	Explain the benefits	Provide evidence or examples	Summary for specific stakeholder
DS0021: Persona (Social Media)		Executives	The following solution to be used to check if anybody is impersonating as an official employee or somebody of the company and if its involving in any malicious activity	The solution is to monitor social media accounts that are impersonating as related to the organization	The benefits of implementing this solution is protecting the reputation of the company by dismissing any disinformations or scamming attempts from anyone impersonating the organization or its staff	for example if anybody impersonates the organization tries scamming it will hurt the reputation of the organization.	The reason why this is a critical issue and why it should be brought to attention is to protect the reputation of the organization by reducing the risk of disinformation against the org and any scams that targets organizations community
DS0029: Network Traffic (Network Traffic Content)		Executives	Employee easily falling victims to phishing attacks for not having proper cybersecurity awareness	Develop course that educated on cybersecurity awareness among the employees and customers.	The benefits of this solution is numerous. Once the employees and customers are taught cybersecurity awareness they will know how to respond to phishing email or anyone trying con them online. Which is how they will fall less likely to the victims of these phishing attacks.	for an example, if an employee is given a mail with malicious files or link, we will be able to identify and block it if we network with the contents traffic.	this is an important matter to this stakeholder because it can help protect us from numerous phishing attack attempts that happen everyday in our daily life. Attacks like this occurs because of the greed for money of the threat actors. if these attack can be stopped or identified, it can save us tons of money in the long run.
T1098: Active Directory (Active Directory Object Modification)		Executives	Not having enough verification process to identify users can lead to unauthorized access, insider threats, and significant business disruption.	Implement multi-factor authentication (MFA) and strict access control for Active Directory modifications, including real-time monitoring and alerts for unusual activity.	Ensures that only authorized personnel can make changes, reducing insider threats and potential data breaches that can cost the company millions in losses and reputational damage.	According to IBM's Cost of a Data Breach Report 2023, breaches caused by compromised credentials cost organizations an average of \$4.5 million. Strengthening identity verification significantly reduces this risk.	Executives should care because a weak identity verification process can result in financial, operational, and reputational harm. Implementing this solution enhances security posture while showing strong leadership in cybersecurity governance.
M1026: Privileged Account Management		Executives	Not having office laptops with limited privileges causing to overuse of admin privileges increasing breach risk & regulatory sanctions.	Implement a privileged access management (PAM) policy that limits administrative access on office devices and enforces the principle of least privilege.	Reduces the attack surface, minimizes insider threat risks, and aligns with cybersecurity best practices and compliance standards.	A 2023 report by CyberArk found that 80% of breaches involve the abuse of privileged credentials. Limiting admin access can drastically reduce this risk.	Executives should care because improper use of admin privileges can lead to costly breaches and regulatory fines. Implementing PAM strengthens security posture and shows a commitment to governance and accountability.
M1057: Data loss prevention		Executives	Not having SIEM solutions deployed on all company devices creates monitoring blind spots and increases the chance of unnoticed data leaks.	Deploy a unified SIEM platform across all endpoints to monitor data flows and detect anomalies that may indicate exfiltration or misuse.	Increases visibility into user activity, prevents data loss, and enables early detection of insider threats or malware-based data theft.	IBM's 2023 report highlights that companies with full visibility into endpoint activity detect breaches 29% faster. SIEM integration closes critical monitoring gaps.	Executives should care because data loss leads to revenue damage, reputational harm, and legal consequences. SIEM ensures data is tracked and protected across all digital assets.
Honeymail to detect phishing email		Executives	Not having a honeymail to spot phishing email leading to receiving more phishing email.	Deploy honeymail: crafted email traps to detect internal phishing attempts.	Provides early warning of campaigns, reduces risk exposure.	Organizations reported 30–50 % drop in successful phishing after honeymail implementation.	Executives should take this as a critical matter because it acts as a preventive measure for any phishing attack happening. Every interaction of the honeymail with the phishing attack can also be well documented.
Honeyfile honeytoken honeydata to detect suspicious activity		Executives	Data may be stealthily exfiltrated without detection, leading to undetected breaches and major losses.	Plant honeyfiles and tokens—decoy data that trigger alerts if accessed improperly.	Enables rapid detection of unauthorized access, especially insider threats or lateral movement attempts.	Companies using honeytokens identified suspicious activity 3x faster, minimizing data breach impact (MITRE).	Executives benefit by gaining stealth breach detection and reducing costly incident impact, especially from insider threats.
Honeycreds to spot unusual login attempt		Executives	Credential-based attacks often go undetected.	Deploy honey credentials—fake but valid-looking credentials planted in systems to alert on unauthorized use.	Detects stolen or guessed credentials being used, especially by attackers performing lateral movement or brute-force attempts.	Organizations using honeycreds detected credential misuse within 15 minutes vs. an average of 24+ hours without	Executives should prioritize this for its fast detection capabilities and ability to limit damage from stolen credentials.

Complete the column's dropdown! 4.3.2 · 4.3.5 · 4.3.8	Solutions sheet first to pre-populate this column's dropdown!	Which audience do you need to communicate value to? 4.4.3	What risk or issue does solution address? 4.4.3	How does solution solve the problem? 4.4.3	Why is solution effective? 4.4.3	What specific examples or statistics can strengthen your argument? 4.4.3	Why should this stakeholder care? 4.4.3
Solution	Stakeholder	State the problem	Propose the solution	Explain the benefits	Provide evidence or examples	Summary for specific stakeholder	
DS0021: Persona (Social Media)	Legal/Compliance	The following solution to be used to check if anybody is impersonating as an official employee or somebody of the company and if its involving in any malicious activity. These impersonations can lead to legal liabilities, defamation, consumer fraud, or breaches of privacy.	The solution is to implement ongoing monitoring of social media platforms to detect and report impersonation accounts, with legal escalation procedures in place for takedowns and cease-and-desist notices.	The benefit of this solution is to ensure the organization is legally protected by actively identifying and addressing impersonation that could result in reputational harm, financial loss, or lawsuits. Proactive mitigation also allows the company to maintain regulatory compliance and reduce exposure to digital fraud.	There has been a significant	The legal and compliance team should care beca	
DS0029: Network Traffic (Network Traffic Content)	Legal/Compliance	Company can be prone to panalties if employees are not trained on cybersecurity awareness.	develop course that educated on cybersecurity awareness among the employees and customers and how it can save company from huge risks.	In case of an audit, employees can provide documentation of the attack and their response. Which should be meeting the compliance of the company.	for example, right after encountering any phishing attack employees can document where they got the attack from and how they responded.	the reason why this is a cirtical issue to the legal team is because it regulates with the compliance and can also provide documentation during an audit.	
T1098: Active Directory (Active Directory Object Modification)	Legal/Compliance	Not having enough verification process to identify users may result in non-compliance with data protection and industry regulations.	Introduce identity governance and access management (IGAM) practices, including role-based access control (RBAC), MFA, and directory auditing to ensure traceability and accountability.	Helps demonstrate due diligence, prevent unauthorized access to sensitive data, and meet audit requirements during compliance checks.	Regulations like GDPR require strict control over who accesses personal data. An unverified AD change could lead to a data leak, resulting in regulatory fines or lawsuits.	Legal and compliance teams should care because implementing stronger verification processes reduces legal liabilities and ensures regulatory compliance across operations.	
M1026: Privileged Account Management	Legal/Compliance	Broad admin access without governance increases non-compliance risks, including failure to meet data protection and access control regulations.	Enforce privileged access policies with user behavior logging, access reviews, and restriction of admin rights to only those with documented business need.	Ensures compliance with regulatory standards like HIPAA, GDPR, or SOX, and creates an auditable trail of privileged activities.	Regulators expect tight control of privileged access—violations can result in fines, lawsuits, or loss of certification.	Legal teams should support this solution to meet access control regulations, limit liability, and ensure forensic traceability in case of a breach.	
M1057: Data loss prevention	Legal/Compliance	Lack of endpoint visibility through SIEM increases risk of non-compliance with data protection and breach notification regulations.	Mandate company-wide SIEM deployment and integrate logging with data loss prevention (DLP) and compliance reporting tools.	Provides detailed audit trails, supports breach detection requirements under laws.	Under GDPR, failure to report data breaches within 72 hours can lead to fines up to €20 million. SIEM can detect and document incidents in real-time.	Legal/compliance teams should prioritize this solution to ensure regulatory compliance, enable rapid reporting, and limit liability during audits or investigations.	
Honeymail to detect phishing email	Legal/Compliance	Lack of early phishing detection may result in breaches that violate data protection regulations.	Deploy honeymail accounts as an early detection mechanism, integrated with incident logging and response tools.	Supports breach prevention, helps meet regulatory requirements for risk monitoring, and shows due diligence in phishing mitigation.	Compliance audits (e.g., under GDPR or HIPAA) reward proactive email threat detection mechanisms like honeymail.	Legal/compliance teams should care because honeymail can help avoid regulatory penalties by proving phishing monitoring and quick response capabilities.	
Honeyfile honeytoken honeydata to detect suspicious activity	Legal/Compliance	Delayed detection of unauthorized access can violate breach notification laws and internal data policies.	Use honeytokens to create provable and monitored access points that generate alerts for sensitive data interactions.	Provides an audit trail for breach attempts, supports regulatory documentation, and demonstrates proactive data governance	Honeytoken-triggered alerts help organizations comply with mandatory breach reporting timelines like those in GDPR and CCPA.	Legal teams benefit from demonstrable controls that satisfy compliance requirements and reduce legal liability in the event of a breach.	
Honeycreds to spot unusual login attempt	Legal/Compliance	Undetected credential abuse may result in unauthorized data access, triggering compliance violations.	Use honeycreds as part of a monitored and auditable credential management strategy.	Demonstrates proactive access control monitoring, supports compliance frameworks like ISO 27001, and aids in breach investigations.	Regulatory frameworks increasingly require user access monitoring—honeycreds offer a way to detect and log suspicious login attempts.	Legal/compliance teams benefit from reduced regulatory risk and improved documentation of access control efforts.	

Complete the column's dropdown! 4.3.2 · 4.3.5 · 4.3.8	Solutions sheet first to pre-populate this column's dropdown! 4.4.3	Which audience do you need to communicate value to? 4.4.3	What risk or issue does solution address? 4.4.3	How does solution solve the problem? 4.4.3	Why is solution effective? 4.4.3	What specific examples or statistics can strengthen your argument? 4.4.3	Why should this stakeholder care? 4.4.3
Solution	Stakeholder	State the problem	Propose the solution	Explain the benefits	Provide evidence or examples	Summary for specific stakeholder	
DS0021: Persona (Social Media)	IT Teams	The following solution to be used to check if anybody is impersonating as an official employee or somebody of the company and if its involving in any malicious activity	The solution is to assign a person who will monitor social media accounts and related work	The benefits of having a person constantly monitor social media helps reduce workload for departments that are working on dismissing disinformations	A person who will constantly handle and monitor social media will be ahead to take any action taken against the reputation of the company. Therefore not resulting in a huge issue which will cause the entire company to struggle	This should be brought to attention because it only requires 1 or 2 people to successfully monitor social media and keep track of all updates. While it increases the number of tasks, it is a good investment for the company to protect its reputation. That way, it will be easier and by splitting the task between 2 people will reduce the workload.	
DS0029: Network Traffic (Network Traffic Content)	IT Teams	employee not being trained enough to idenitfy phisihing attacks from threat actors.	develop course that educated on cybersecurity awareness among the employees and customers.	Implementing this single solution can save a lot of time for the IT teams and also make it easier for the team. Once all employees are properly trained, it teams will not have to worry about falling victim to the phishing attacks.	as an example, if an employee who is trained on cybersecurity awareness gets phishing attacks, they can indentify and let the IT teams to handle things from there. Now in an opposite scenario, if the employee fell victim to the phishing attack, there can be distastrous result with little to no recover	this should be an important matter to the IT teams since it will help make their work easier for the team and also save plenty of time and risk in the long run.	
T1098: Active Directory (Active Directory Object Modification)	IT Teams	Weak verification process in Active Directory allows unauthorized modifications and creates blind spots in incident detection.	Deploy stronger access controls, including group policy restrictions, administrative approval workflows, and logging of all directory object changes.	Enhances security, simplifies troubleshooting, and allows for fast response to incidents by having a clear audit trail of changes.	For example, if a malicious insider changes group memberships or privileges, enhanced logging and approvals can immediately flag and reverse such activity	IT teams should care because these enhancements prevent exploitation of directory weaknesses, reduce cleanup time post-breach, and improve overall system integrity.	
M1026: Privileged Account Management	IT Teams	Admin access is widely distributed across endpoints, making it difficult to manage and increasing the risk of privilege misuse or malware execution.	Centralize privileged account management and enforce role-based access, with time-bound or just-in-time (JIT) admin rights for specific tasks.	Reduces the risk of malware propagation, simplifies incident response, and improves auditing and control over user actions.	For example, malware like TrickBot exploits local admin rights to escalate privileges. Removing default admin rights can block such lateral movement.	IT teams should care because this approach improves operational control, lowers risk, and simplifies endpoint security management.	
M1057: Data loss prevention	IT Teams	Without SIEM integration on all endpoints, IT teams lack real-time alerts and forensics data needed to detect and respond to breaches efficiently.	Standardize SIEM agents on all company-managed devices and configure them to detect unauthorized access, data movement, and unusual patterns.	Enhances threat detection, simplifies investigations, and allows for automation in incident response.	For example, in a data exfiltration attempt, SIEM logs can reveal abnormal upload activity, device access time, and potential data paths—enabling rapid containment.	IT teams should support this for improved detection, easier root cause analysis, and a more robust security monitoring framework.	
Honeyemail to detect phishing email	IT Teams	IT lacks proactive detection tools to catch phishing attempts before users interact with malicious emails.	Implement honeyemail traps—email addresses never used for communication but monitored for incoming phishing.	Allows IT to detect and block phishing campaigns early, adjust email filters, and simulate attacks for awareness training.	Teams using honeyemail reported faster response times and a 60% reduction in email compromise incidents (source: Cofense).	IT teams should support this because it strengthens email defenses, enables proactive phishing detection, and improves response time.	
Honeyfile honeypot honeydata to detect suspicious activity	IT Teams	Without decoys or triggers, unauthorized access can go unnoticed until it's too late.	Deploy honeyfiles and tokens across file servers and sensitive locations.	Enables early detection of suspicious activity, assists in threat hunting, and improves visibility in dark corners of the network.	Internal security teams using honeyfiles reduce incident detection time by 40%	IT teams should support this for its low cost, high-detection value, and real-time alerting on unauthorized access attempts.	
Honeycreds to spot unusual login attempt	IT Teams	IT lacks early-warning mechanisms to identify compromised credentials in real time.	Plant honeycreds in key systems and monitor authentication attempts involving them.	Provides an instant signal of malicious access attempts, reducing dwell time and improving incident response.	Tools like Canarytokens and MITRE techniques show honeycreds can surface credential theft attempts missed by traditional monitoring.	IT teams benefit from faster incident detection, clearer visibility, and improved credential security posture.	